BÀI TẬP LUYỆN TẬP

Học phần: An toàn và bảo mật thông tin

ThS. Nguyễn Quốc Thái

quocthai@neu.edu.vn

Mục lục

Chương 1: Tổng quan về an toàn và bảo mật thông tin **4**

Bài 1. Mối đe doạ và hiểm hoạ 4
Bài 2. Quản lý rủi ro 4
Bài 3. Bốn mục tiêu chung: bí mật, toàn vẹn, xác thực, sẵn sàng 5
Bài 4. Kể tên ba thành phần chính của ATBMTT. 5
Bài 5. Kẻ xâm nhập và chu trình xâm nhập 6
Bài 6. Virus là gì? Bộ tải của virus là gì? 6
Bài 7. Phần mềm có hại và tấn công từ chối dịch vụ 6
Bài 8. Tràn bộ đệm 7
Bài 9. Chọn giải pháp cho từng tình huống 7
Bài 10. Thủ tục bắt tay SSL cho phép máy chủ và máy trạm làm những việc gì? 8
Bài 11. Vẽ sơ đồ phong bì số: dữ liệu và khoá phiên được mã bằng gì? 8

Chương 2: Mã hoá khoá đối xứng **9**

Bài 1. Vẽ mô hình mã hoá đối xứng. Trong mã đối xứng, khoá KE và khoá KD quan hệ thế nào? 9
Bài 2. Thám mã và độ an toàn 9
Bài 3. Mã Caesar và mã bảng chữ đơn 9
Bài 4. Mã Playfair 10

Bài 5. Mã Vigenère và mã Rail Fence . . . 10
Bài 6. Mã dịch chuyển dòng . . . 10
Bài 7. Hệ mã TinyA5/1 . . . 10
Bài 8. Hệ mã TinyRC4 . . . 11
Bài 9. Hệ mã TinyDES . . . 11
Bài 10. Nêu bốn tính chất của hệ mã DES. . . . 12
Bài 11. A gửi một bản mã cho B. Kẻ thứ ba C chặn bản mã đó rồi gửi lại cho B, nên B nhận được cùng một bản rõ hai lần. Đây là kiểu tấn công gì? . . . 12
Bài 12. Vì sao mã hoá đối xứng không thực hiện được tính không từ chối? . . . 12
Bài 13. Mô hình KDC thiết lập khoá chung KAB qua những bước nào? . . . 12

Chương 3: Mã hoá khoá công khai **13**

Bài 1. Vẽ sơ đồ mã hoá khoá công khai. Khoá công khai và khoá riêng mỗi loại dùng làm gì? 13
Bài 2. Thuật toán Euclide và Euclide mở rộng . . . 13
Bài 3. Phần tử nghịch đảo và phương trình đồng dư . . . 13
Bài 4. Thuật toán Bình phương và nhân . . . 13
Bài 5. Hàm Ơle và định lý Ferma . . . 14
Bài 6. Định lý phần dư Trung Hoa . . . 14
Bài 7. Hệ mã ba lô (hệ mã MHK) . . . 14
Bài 8. Hệ mã RSA . . . 14
Bài 9. Kể tên bốn cách phân phối khoá công khai. . . . 15
Bài 10. PKI là gì? Kể tên các thành phần của PKI. . . . 15
Bài 11. Phát biểu: có thể dùng Diffie-Hellman để mã hoá và gửi mẩu tin. Đúng hay sai, vì sao? 15
Bài 12. Chữ ký số RSA và trao đổi khoá Diffie-Hellman . . . 15

Chương 4: Hàm băm và chữ ký điện tử **16**

Bài 1. Hàm băm là gì? Đầu vào và đầu ra của nó khác nhau ở chỗ nào? . . . 16
Bài 2. Khái niệm và ba tính chất của hàm băm . . . 16
Bài 3. Tấn công nghịch lý ngày sinh . . . 16
Bài 4. Hàm băm MD5: đệm và đếm . . . 16
Bài 5. MD5 thu nhỏ: một bước biến đổi . . . 17
Bài 6. Hàm băm SHA . . . 18
Bài 7. Chữ ký điện tử khác chữ ký thông thường ở những chỗ nào? . . . 18
Bài 8. Sơ đồ chữ ký điện tử là bộ 5 tham số nào? Nêu ý nghĩa từng tham số. . . . 18
Bài 9. A muốn gửi B một bức điện vừa được ký vừa được mã hoá. A làm theo thứ tự nào? . . 18
Bài 10. Hệ chữ ký điện tử RSA . . . 18
Bài 11. Chuẩn chữ ký điện tử DSS . . . 19

Đáp án gợi ý **20**

Chương 1: Tổng quan về an toàn và bảo mật thông tin 20

Chương 2: Mã hoá khoá đối xứng 23

Chương 3: Mã hoá khoá công khai 25

Chương 4: Hàm băm và chữ ký điện tử 26

Chương 1: Tổng quan về an toàn và bảo mật thông tin

Bài 1. Mối đe doạ và hiểm hoạ

Với mỗi tình huống, trả lời ba câu hỏi. (a) Tình huống thuộc mối đe doạ nào trong ba mối đe doạ: phá hoại, sửa đổi, can thiệp? Nếu chưa thuộc mối đe doạ nào thì nói rõ vì sao. (b) Đó là hiểm hoạ vô tình hay cố ý? (c) Đó là hiểm hoạ thụ động hay chủ động?

TT	Tình huống
1	Nhân viên vệ sinh vô ý rút phích cắm tủ máy chủ, dịch vụ ngừng hai giờ.
2	Kẻ tấn công đặt thiết bị bắt gói tin trên đường truyền để đọc thư nội bộ, không sửa gì.
3	Quản trị viên khởi động máy chủ ở chế độ đặc quyền rồi quên chuyển về chế độ thông thường.
4	Kẻ tấn công sửa số tiền trên lệnh chuyển khoản đang được truyền đi.
5	Một nhân viên dùng đúng tài khoản của mình để mở hồ sơ lương của phòng khác.
6	Một con sâu lây lan trong mạng nội bộ làm toàn bộ mạng chậm hẳn lại.

Bài 2. Quản lý rủi ro

Một trung tâm dữ liệu đã thống kê được năm rủi ro sau. Đơn vị tổn thất: triệu đồng.

Mã	Rủi ro	Xác suất xảy ra trong một năm	Tổn thất mỗi lần	Tổn thất kỳ vọng
R1	Mất điện kéo dài ở phòng máy chủ	0,50	120	
R2	Nhân viên làm lộ mật khẩu tài khoản quản trị	0,30	400	
R3	Mã độc tống tiền mã hoá dữ liệu nghiệp vụ	0,10	3.000	
R4	Hỏng ổ cứng máy chủ cơ sở dữ liệu	0,40	250	
R5	Tấn công từ chối dịch vụ vào cổng dịch vụ	0,25	600	

Bốn giải pháp bảo vệ được chào với chi phí một năm như sau. Ngân sách tối đa: **250 triệu đồng một năm**.

Mã	Giải pháp	Chi phí một năm	Tác dụng
G1	Sao lưu ngoại tuyến hằng ngày	80	Giảm 80% tổn thất kỳ vọng của R3 và 50% của R4
G2	Xác thực hai yếu tố cho tài khoản quản trị	60	Giảm 90% tổn thất kỳ vọng của R2
G3	Thuê dịch vụ chống tấn công từ chối dịch vụ	120	Giảm 70% tổn thất kỳ vọng của R5
G4	Máy phát điện dự phòng cho phòng máy chủ	100	Giảm 90% tổn thất kỳ vọng của R1

(1) Tính tổn thất kỳ vọng một năm của từng rủi ro và của cả hệ thống; xếp năm rủi ro theo thứ tự cần xử lý trước.

(2) Với mỗi giải pháp, tính phần tổn thất kỳ vọng giảm được, lợi ích ròng và tỉ lệ lợi ích trên chi phí.

(3) Chọn tổ hợp giải pháp tối ưu trong giới hạn ngân sách, tức tổ hợp có tổng lợi ích ròng lớn nhất. Tổn thất kỳ vọng còn lại là bao nhiêu? Vì sao có giải pháp không nên mua dù ngân sách vẫn còn?

(4) Ban giám đốc đặt yêu cầu: tổn thất kỳ vọng còn lại không vượt quá 350 triệu đồng một năm. Tổ hợp vừa chọn có đạt yêu cầu đó không? Liên hệ với nguyên tắc *giảm rủi ro đến mức chấp nhận được* của bài giảng.

Bài 3. Bốn mục tiêu chung: bí mật, toàn vẹn, xác thực, sẵn sàng

(1) Mỗi sự cố dưới đây vi phạm thuộc tính nào, và bài giảng gán cho thuộc tính đó những công cụ bảo vệ nào?

TT	Sự cố
1	Kẻ tấn công chặn đường truyền và đọc được số thẻ ngân hàng của khách hàng.
2	Số tiền 1 triệu trên một lệnh chuyển khoản bị sửa thành 10 triệu.
3	Cổng dịch vụ ngân hàng điện tử bị làm quá tải, khách hàng không truy cập được.
4	Một người lạ gửi lệnh chuyển tiền và hệ thống tưởng đó là chủ tài khoản.
5	Ổ cứng chứa bản sao lưu duy nhất bị hỏng, không khôi phục được dữ liệu.

(2) Một sự cố có thể vi phạm đồng thời nhiều thuộc tính không? Cho một ví dụ và chỉ rõ từng thuộc tính bị vi phạm.

Bài 4. Kể tên ba thành phần chính của ATBMTT.

Bài 5. Kẻ xâm nhập và chu trình xâm nhập

(1) Xếp mỗi nhân vật vào một trong ba loại kẻ xâm nhập. Nhân vật nào không xếp được, nói rõ vì sao.

TT	Nhân vật
1	Một người ngoài công ty dùng mật khẩu đánh cắp được để đăng nhập với tư cách nhân viên.
2	Nhân viên kế toán mở hồ sơ lương của giám đốc dù công việc không yêu cầu.
3	Kẻ tấn công đã lên được quyền quản trị, việc đầu tiên là tắt tính năng ghi nhật ký.
4	Một người ở ngoài Internet quét cổng máy chủ của công ty nhưng chưa vào được hệ thống.

(2) Kể bốn bước của chu trình xâm nhập điển hình theo đúng thứ tự và nói ngắn gọn mỗi bước làm gì.

(3) Bài giảng nêu bốn cách tiếp cận phát hiện xâm nhập. Với nhân vật số 3 ở ý (1), cách nào gần như vô hiệu và cách nào còn cơ hội phát hiện? Giải thích.

Bài 6. Virus là gì? Bộ tải của virus là gì?

Bài 7. Phần mềm có hại và tấn công từ chối dịch vụ

(1) Xếp sáu loại mã độc sau vào một bảng hai chiều: virus, sâu, cửa sau, bom logic, ngựa thành Tơ-roa, zombie. Hàng của bảng: *có tự sinh lặp hay không*. Cột của bảng: *ai đưa mã độc vào máy nạn nhân*, gồm hai cột là người phát triển cài sẵn, và người dùng tự rước vào hoặc kẻ tấn công cài.

(2) **Bài tính.** Một máy chủ xử lý được tối đa **25.000 yêu cầu mỗi giây**. Lưu lượng của người dùng thật lúc cao điểm là **8.000 yêu cầu mỗi giây**.

- (a) Một máy lạ gửi thêm 10.000 yêu cầu mỗi giây. Tổng lưu lượng là bao nhiêu, máy chủ có quá tải không?
- (b) Thay vào đó là một mạng 100.000 máy zombie, mỗi máy chỉ gửi 1 yêu cầu mỗi giây. Tổng lưu lượng là bao nhiêu, gấp mấy lần năng lực máy chủ?
- (c) Quản trị viên đặt giới hạn **2 yêu cầu mỗi giây cho mỗi địa chỉ**. Biện pháp này chặn được trường hợp nào trong hai trường hợp trên, không chặn được trường hợp nào? Vì sao?
- (d) Muốn chịu được trường hợp (b) chỉ bằng cách tăng năng lực, phải tăng gấp mấy lần? Nhận xét về tính khả thi.

(3) Bài giảng chia các biện pháp chống tấn công từ chối dịch vụ theo ba mốc thời gian. Kể tên ba mốc và mỗi mốc một biện pháp.

Bài 8. Tràn bộ đệm

Một chương trình viết bằng C có khung ngăn xếp xếp theo chiều địa chỉ tăng dần như sau:

Vùng nhớ	Kích thước
Bộ đệm nhận chuỗi nhập vào	64 byte
Các biến cục bộ khác	8 byte
Con trỏ khung đã lưu	4 byte
Địa chỉ trả về	4 byte

(1) Chương trình đọc chuỗi nhập vào mà không kiểm tra độ dài. Phải nhập bao nhiêu byte thì byte tiếp theo bắt đầu ghi đè lên địa chỉ trả về? Phải nhập bao nhiêu byte để ghi đè trọn vẹn địa chỉ trả về?

(2) Trình biên dịch được bật cơ chế chèn một giá trị ngẫu nhiên 4 byte ngay trước con trỏ khung. Hai con số ở ý (1) thay đổi thế nào? Kẻ tấn công có đạt mục đích không, vì sao?

(3) Nêu tác dụng của hai cơ chế bảo vệ thời gian chạy mà bài giảng nhắc tới. Trong ba cơ chế stack canary, DEP/NX bit và ASLR, cơ chế nào áp dụng được cho chương trình **đã biên dịch sẵn**, cơ chế nào bắt buộc phải biên dịch lại?

(4) Vì sao lỗi này tồn tại từ năm 1988 tới nay? Nêu cách phòng đơn giản nhất ở mức lập trình.

Bài 9. Chọn giải pháp cho từng tình huống

(1) Chọn giải pháp phù hợp nhất cho mỗi tình huống và giải thích vì sao. Nếu chọn IPSec, nêu rõ dùng AH hay ESP, ở chế độ nào.

TT	Tình huống
1	Lọc lưu lượng ở cổng ra vào theo địa chỉ IP và số hiệu cổng, ưu tiên tốc độ, chấp nhận mức an toàn thấp.
2	Kiểm tra nội dung và cú pháp của từng dịch vụ HTTP, FTP, SMTP trước khi cho qua.
3	Hai máy chủ trong cùng một trung tâm dữ liệu cần chắc chắn dữ liệu không bị sửa và đúng nguồn gốc; nội dung phải để rõ vì hệ thống phát hiện xâm nhập đặt giữa hai máy phải đọc được tải trọng.
4	Nối hai văn phòng ở hai thành phố qua Internet thành một mạng riêng ảo, giấu luôn địa chỉ IP nội bộ.
5	Gửi một thư điện tử bảo mật cho đối tác. Hai bên chưa có khoá bí mật chung, nhưng người gửi đã có khoá công khai của đối tác.

(2) Điền ba ô còn trống trong bảng so sánh ba loại tường lửa:

Tiêu chí	Bộ lọc gói	Cổng mức ứng dụng	Cổng mức mạch
Tầng hoạt động	…	Tầng ứng dụng	Tầng phiên
Mức an toàn	Thấp	…	Trung bình
Điểm yếu chính	Dễ bị qua mặt bằng giả mạo địa chỉ IP	Cần một proxy riêng cho mỗi dịch vụ	…

(3) Lệnh `ls -l` trong Linux hiện quyền `rwx` của từng tệp. Đó là cách cắt ma trận kiểm soát truy cập theo chiều nào, và chiều đó mang tên gì? Chiều còn lại tên gì và biểu diễn cái gì?

(4) Nêu ba hạn chế của tường lửa và cho mỗi hạn chế một ví dụ.

Bài 10. Thủ tục bắt tay SSL cho phép máy chủ và máy trạm làm những việc gì?

Bài 11. Vẽ sơ đồ phong bì số: dữ liệu và khoá phiên được mã bằng gì?

Chương 2: Mã hoá khoá đối xứng

Bài 1. Vẽ mô hình mã hoá đối xứng. Trong mã đối xứng, khoá KE và khoá KD quan hệ thế nào?

Bài 2. Thám mã và độ an toàn

(1) Xác định kiểu tấn công thám mã trong mỗi tình huống và xếp bốn tình huống theo thứ tự kẻ tấn công từ yếu đến mạnh:

TT	Tình huống
1	Kẻ tấn công chỉ bắt được bản mã trên đường truyền và biết thuật toán đang dùng.
2	Kẻ tấn công có sẵn vài cặp bản rõ, bản mã của những lần liên lạc trước.
3	Kẻ tấn công nhập được bản rõ do mình chọn vào hệ thống và nhận lại bản mã tương ứng.
4	Kẻ tấn công vừa đưa được bản rõ tự chọn vào để lấy bản mã, vừa đưa được bản mã tự chọn vào để lấy bản rõ.

(2) **Bài tính.** Một máy thử được 10^6 khoá mỗi giây.

- (a) Khoá dài 32 bít: phải thử tối đa bao nhiêu khoá và mất bao lâu?
- (b) Khoá dài 56 bít (bằng độ dài khoá DES): mất bao lâu? Trả lời theo đơn vị năm, lấy 1 năm = 365 ngày.
- (c) Mỗi khi thêm một bít vào khoá thì thời gian duyệt thay đổi thế nào?
- (d) Một bản tin chỉ còn giá trị trong 1 giờ. Xét thời gian dò khoá trung bình (thử một nửa số khoá), khoá 32 bít có đủ bảo vệ nó không? Nếu tăng lên 34 bít thì sao?

(3) Phân biệt an toàn không điều kiện và an toàn tính toán. Hệ mã nào đạt mức thứ nhất?

Bài 3. Mã Caesar và mã bảng chữ đơn

(1) Mã hoá bản rõ `NETWORK` bằng mã Caesar với khoá k = 11.

(2) Giải mã bản mã `XLMWMWEXIWX` biết khoá k = 4.

(3) Biết bản rõ `SECRET` được mã thành `BNLANC`. Tìm khoá k.

(4) Cho bảng thay thế của một mã bảng chữ đơn:
```
Plain : abcdefghijklmnopqrstuvwxyz
Cipher: DKVQFIBJWPESCXHTMYAUOLRGZN
```
Hãy mã hoá `CODE` và giải mã `TYHUHVHS`.

(5) Mã Caesar có bao nhiêu khoá hữu ích, mã bảng chữ đơn có bao nhiêu khoá? Vì sao số khoá lớn hơn rất nhiều mà mã bảng chữ đơn vẫn bị phá bằng giấy bút?

Bài 4. Mã Playfair

Từ khoá: `KEYWORD`. Quy ước: gộp I và J vào một ô, chữ chèn là X (dùng X cả khi một cặp có hai chữ giống nhau lẫn khi bản rõ còn lẻ một chữ cuối).

(1) Lập ma trận 5×5 từ từ khoá trên.

(2) Tách bản rõ `CRYPTO` thành các cặp rồi mã hoá.

(3) Mã hoá `SUCCESS`. Chú ý bước tách cặp, giải thích vì sao bản mã dài hơn bản rõ.

(4) Mã hoá `MESSAGE`, rồi giải mã lại bản mã vừa thu được để kiểm tra. Bản rõ khôi phục có giống hệt bản rõ ban đầu không? Vì sao?

Bài 5. Mã Vigenère và mã Rail Fence

(1) Mã hoá `INFORMATION` bằng Vigenère với từ khoá `KEY`.

(2) Giải mã `OAMOAAQCVQBTP` với từ khoá `CAT`.

(3) Mã hoá `NETWORKSECURITY` bằng Rail Fence với 3 dòng.

(4) Giải mã `CGRORYYTAHPP` biết được mã bằng Rail Fence với 4 dòng.

(5) Vì sao Vigenère khó phá bằng thống kê tần suất hơn Caesar?

Bài 6. Mã dịch chuyển dòng

(1) Mã hoá `SECURITYFIRST` với 4 cột, dãy khoá `2 4 1 3`. Đệm bằng chữ X cho đủ lưới.

(2) Giải mã `AVOOTOMNEHICAHT` biết lưới gồm 5 cột và dãy khoá `3 1 4 2 5`.

(3) So sánh bảng tần suất chữ cái của bản rõ và bản mã ở ý (1). Nhận xét, và cho biết dấu hiệu này giúp phân biệt mã thay thế với mã hoán vị như thế nào.

Bài 7. Hệ mã TinyA5/1

Bản rõ P = `101` (chữ F), khoá K = `10100010000110001000010` (23 bít). Quy ước: các ô của mỗi thanh ghi đánh số từ 0: X là $x_0 \ldots x_5$, Y là $y_0 \ldots y_7$, Z là $z_0 \ldots z_8$; bước đầu tiên là bước i = 0. Nhắc lại: m là giá trị đa số của x_1, y_3, z_3; thanh ghi nào có bít điều khiển bằng m thì quay (dịch phải một ô, ô 0 nhận bít $t_X = x_2 \oplus x_4 \oplus x_5$, $t_Y = y_6 \oplus y_7$, $t_Z = z_2 \oplus z_7 \oplus z_8$); $s_i = x_5 \oplus y_7 \oplus z_8$ lấy sau khi quay.

(1) Phân bổ khoá K vào ba thanh ghi X (6 bít), Y (8 bít), Z (9 bít).

(2) Thực hiện ba bước sinh số. Mỗi bước ghi rõ x_1, y_3, z_3, giá trị m, những thanh ghi được quay, nội dung ba thanh ghi sau khi quay và bít s_i.

Bước	x_1	y_3	z_3	m	Quay	X sau bước	Y sau bước	Z sau bước	s_i
0									
1									
2									

(3) Tính C = P $\oplus$ S và cho biết chữ cái tương ứng (A = 000 … H = 111).

(4) Nhìn lại cột *Quay*: mỗi bước có thể có bao nhiêu thanh ghi cùng được quay? Chứng minh không bao giờ xảy ra trường hợp chỉ một thanh ghi quay.

Bài 8. Hệ mã TinyRC4

Bản rõ P = `011 100 010` (từ DEC), khoá K gồm 3 số: `5, 2, 7` (N = 3).

(1) Lập dãy T, rồi chạy giai đoạn khởi tạo. Ghi dãy S sau mỗi lần hoán đổi và dãy S cuối cùng.

i	j	S sau khi Swap
0		
1		
2		
3		
4		
5		
6		
7		

(2) Thực hiện ba bước sinh số, tìm ba số k, đổi sang nhị phân 3 bít rồi ghép thành dãy S.

Bước	i	j	S sau khi Swap	t	k
0					
1					
2					

(3) Tính C = P $\oplus$ S và cho biết từ tương ứng (A = 000 … H = 111).

(4) Sau giai đoạn khởi tạo, còn phần tử nào của S đứng đúng vị trí ban đầu không? Điều đó nói lên nhiệm vụ của giai đoạn khởi tạo là gì?

Bài 9. Hệ mã TinyDES

Bản rõ P = `01010011` (53_{16}), khoá K = `10111011` (BB_{16}).

Nhắc lại các hàm (các bít đánh số từ trái sang phải, bắt đầu từ 0): **Expand** biến 4 bít $b_0b_1b_2b_3$ thành 6 bít $b_2b_3b_1b_2b_1b_0$. **S-box** lấy 6 bít $b_0b_1b_2b_3b_4b_5$, trong đó b_0b_5 chọn hàng và $b_1b_2b_3b_4$ chọn cột, cho ra 4 bít (bảng dưới, viết theo hệ mười sáu). **P-box** hoán vị 4 bít $b_0b_1b_2b_3$ thành $b_2b_0b_3b_1$. **Sinh khoá con:** chia K thành KL_0 và KR_0 mỗi nửa 4 bít; mỗi nửa dịch vòng trái riêng, vòng 1 dịch 1 bít, vòng 2 dịch tiếp 2 bít, vòng 3 dịch tiếp 1 bít; khoá con K_i = Compress(KL_iKR_i) lấy $k_5k_1k_3k_2k_7k_0$.

Hàng \ Cột	0000	0001	0010	0011	0100	0101	0110	0111	1000	1001	1010	1011	1100	1101	1110	1111
00	E	4	D	1	2	F	B	8	3	A	6	C	5	9	0	7
01	0	F	7	4	E	2	D	1	A	6	C	B	9	5	3	8
10	4	1	E	8	D	6	2	B	F	C	9	7	3	A	5	0
11	F	C	8	2	4	9	1	7	5	B	3	E	A	0	6	D

(1) Sinh ba khoá con K_1, K_2, K_3.

(2) Mã hoá P qua đủ ba vòng Feistel. Mỗi vòng ghi rõ Expand(R_{i-1}), Expand $\oplus$ K_i, S-box, F, L_i và R_i. Cho biết bản mã C.

(3) Giải mã C vừa thu được **theo đúng hai công thức giải mã của mô hình Feistel**: $R_{i-1} = L_i$ và $L_{i-1} = R_i \oplus F(R_{i-1}, K_i)$, khoá con lấy theo thứ tự K_3, K_2, K_1. Kết quả có trở về đúng bản rõ P không?

(4) Một bạn kiểm tra bằng cách khác: chạy lại *sơ đồ mã hoá* trên bản mã C với khoá con đảo thứ tự K_3, K_2, K_1. Hãy làm thử và cho biết kết quả. Vì sao cách này không trả về bản rõ?

Bài 10. Nêu bốn tính chất của hệ mã DES.

Bài 11. A gửi một bản mã cho B. Kẻ thứ ba C chặn bản mã đó rồi gửi lại cho B, nên B nhận được cùng một bản rõ hai lần. Đây là kiểu tấn công gì?

Bài 12. Vì sao mã hoá đối xứng không thực hiện được tính không từ chối?

Bài 13. Mô hình KDC thiết lập khoá chung KAB qua những bước nào?

Chương 3: Mã hoá khoá công khai

Bài 1. Vẽ sơ đồ mã hoá khoá công khai. Khoá công khai và khoá riêng mỗi loại dùng làm gì?

Bài 2. Thuật toán Euclide và Euclide mở rộng

(1) Dùng thuật toán Euclide tìm GCD(2415, 945). Lập bảng từng phép chia.

(2) Dùng thuật toán Euclide tìm GCD(1769, 551).

(3) Dùng Euclide mở rộng tìm d = GCD(1239, 735) và hai số nguyên x, y thoả `1239x + 735y = d`.

(4) Tương tự với `1001x + 357y = d`. Thử lại kết quả bằng cách thay x, y vào đẳng thức.

Bài 3. Phần tử nghịch đảo và phương trình đồng dư

Dùng bảng 6 cột của bài giảng (mẫu dưới), đánh số từ dòng 0; số dòng tuỳ từng phép tính.

Dòng	r_0	r_1	r_2	q	t_0	t_1
0						
1						
2						
3						

(1) Tính $37^{-1} \bmod 120$.

(2) Tính $26^{-1} \bmod 91$. Nếu không tồn tại, hãy chỉ ra bảng dừng ở đâu và giải thích bằng điều kiện tồn tại nghịch đảo.

(3) Giải phương trình đồng dư $37x \equiv 11 \pmod{120}$ dựa trên kết quả ý (1).

(4) Điều kiện cần và đủ để a có nghịch đảo theo modulo n là gì? Số nghịch đảo đó có duy nhất không?

Bài 4. Thuật toán Bình phương và nhân

Lập bảng bốn hàng i, b_i, c, f như ví dụ trong bài giảng.

(1) Tính $5^{117} \bmod 19$.

(2) Tính $3^{200} \bmod 23$.

(3) Nếu tính thẳng `3^200` rồi mới lấy modulo thì số đó có bao nhiêu chữ số (gợi ý: số chữ số của x là $\log_{10} x + 1$)? Nêu lợi ích của việc rút gọn theo modulo ở mỗi bước.

Bài 5. Hàm Ơle và định lý Ferma

(1) Tính Φ(n) với n = 61, 85, 125, 144.

(2) Dùng định lý Ferma hoặc định lý Ơle để tính nhanh, không cần lập bảng luỹ thừa:

- $4^{102} \bmod 103$
- $5^{96} \bmod 13$
- $2^{100} \bmod 33$

(3) Định lý Ferma đòi điều kiện gì ở a và p? Cho một ví dụ áp dụng sai vì vi phạm điều kiện đó.

Bài 6. Định lý phần dư Trung Hoa

(1) Tìm số nguyên dương x nhỏ nhất thoả đồng thời $x \equiv 1 \pmod 5$, $x \equiv 4 \pmod 7$, $x \equiv 6 \pmod{11}$.

(2) Dùng định lý phần dư Trung Hoa để tính $7^{129} \bmod 55$ bằng cách tách theo hai thừa số 5 và 11.

(3) Vì sao định lý này giúp tăng tốc phép giải mã RSA?

Bài 7. Hệ mã ba lô (hệ mã MHK)

Cho $A' = (3, 5, 11, 21, 44)$, N = 5, M = 97, u = 34.

(1) Kiểm tra A' có phải véc tơ siêu tăng không, và kiểm các điều kiện của M và u theo sơ đồ hệ mã MHK.

(2) Tìm khoá của hệ mã: Kp = (S, M) và Ks = (u, u^{-1}).

(3) Mã hoá bản rõ P = $(x_1x_2x_3x_4x_5)$ = 10110.

(4) Giải mã bản mã C = 57: tính $C' = C \cdot u^{-1} \bmod M$ rồi giải bài toán xếp ba lô 0/1 với A' và C'. Trình bày từng vòng so sánh.

(5) Vì sao người ngoài không giải được bài toán ba lô với véc tơ S, trong khi người nhận lại giải được dễ dàng với A'?

Bài 8. Hệ mã RSA

Cho p = 13, q = 23, khoá mã hoá e = 17.

(1) Tính N và Φ(N); kiểm điều kiện của e.

(2) Tìm khoá giải mã d. Ghi rõ bộ khoá công khai KU và bộ khoá riêng KR.

(3) Mã hoá bản rõ M = 100 bằng thuật toán Bình phương và nhân (lập bảng).

(4) Giải mã bản mã vừa thu được để kiểm tra lại.

(5) Vì sao phải giữ bí mật p và q chứ không chỉ giữ d?

Bài 9. Kể tên bốn cách phân phối khoá công khai.

Bài 10. PKI là gì? Kể tên các thành phần của PKI.

Bài 11. Phát biểu: có thể dùng Diffie-Hellman để mã hoá và gửi mẩu tin. Đúng hay sai, vì sao?

Bài 12. Chữ ký số RSA và trao đổi khoá Diffie-Hellman

(1) Dùng bộ khoá RSA p = 13, q = 23, e = 17, hãy ký bản tin M = 42 rồi kiểm chứng chữ ký (khoá d tự tính hoặc lấy từ bài Hệ mã RSA ở trên).

(2) Với cùng bộ khoá ở ý (1), một người nhận được cặp (M = 50, S = 191). Hãy kiểm chứng và cho biết chữ ký có hợp lệ không, vì sao.

(3) Trao đổi khoá Diffie-Hellman với q = 467, $\alpha = 2$ (α là căn nguyên tố của mod 467). A chọn $x_A = 153$, B chọn $x_B = 219$. Tính y_A, y_B và khoá phiên chung K_{AB} theo cả hai chiều.

(4) Kẻ nghe trộm bắt được q, α, y_A, y_B. Hắn phải giải bài toán gì để tìm K_{AB}?

Chương 4: Hàm băm và chữ ký điện tử

Bài 1. Hàm băm là gì? Đầu vào và đầu ra của nó khác nhau ở chỗ nào?

Bài 2. Khái niệm và ba tính chất của hàm băm

(1) Mô tả sơ đồ chữ ký có dùng hàm băm: bên ký làm gì, phát đi những gì, bên nhận làm gì. Vì sao bên ký không gửi kèm cốt bức điện?

(2) Phát biểu ba tính chất của hàm băm. Chỉ rõ điểm khác nhau giữa tính *không đụng độ cao* và tính *đụng độ cao*.

(3) Mỗi tình huống sau vi phạm tính chất nào?

TT	Tình huống
1	Kẻ tấn công lấy được tệp chỉ chứa các cốt và tìm ra bức điện sinh ra một cốt trong đó.
2	Một hợp đồng đã công bố kèm cốt; kẻ gian soạn được hợp đồng khác có đúng cốt ấy.
3	Kẻ gian tự soạn hai hợp đồng khác nhau nhưng có cùng cốt, rồi đưa một bản đi ký.

(4) Nếu hàm băm cho phép tìm hai bức điện cùng cốt thì sơ đồ chữ ký ở ý (1) hỏng thế nào?

Bài 3. Tấn công nghịch lý ngày sinh

(1) Phát biểu nghịch lý ngày sinh. Khi chuyển sang tấn công hàm băm thì n và k lần lượt ứng với đại lượng nào?

(2) Điền bảng sau (viết kết quả dưới dạng luỹ thừa của 2):

Độ dài cốt	Số giá trị băm n	Số phép thử để có xác suất đụng độ khoảng 50%
64 bít		
128 bít		
160 bít		

(3) Một hàm băm cho cốt dài 3 byte. Tính n và số phép thử để có đụng độ (theo quy tắc ở ý 2).

(4) Một máy thực hiện được 2^{30} phép thử mỗi giây. Với hàm băm cho cốt dài 96 bít, máy cần bao lâu để làm hết số phép thử tìm đụng độ (tính theo quy tắc ở ý 2)? Trả lời theo đơn vị ngày.

(5) Vì sao cốt 128 bít từng được coi là đủ nhưng nay không còn được khuyến nghị?

Bài 4. Hàm băm MD5: đệm và đếm

Quy ước đệm dùng trong cả tài liệu này

Thêm một bít **"1"** vào cuối bức điện, rồi thêm các bít **"0"** cho tới khi độ dài chia hết cho 512: **không** có trường 64 bít ghi độ dài. Đây là quy ước trên slide bài giảng. Chuẩn MD5 (RFC 1321) có thêm trường 64 bít nên cho kết quả khác.

(1) Với mỗi độ dài bức điện dưới đây, tính: số bít "0" phải thêm, tổng độ dài sau khi đệm, số khối 512 bít, số từ 32 bít và tổng số lần biến đổi với hàm phi tuyến.

Bức điện	Số bít "0" thêm vào	Tổng sau khi đệm	Số khối	Số từ 32 bít	Số lần biến đổi
700 bít					
1024 bít					
3000 bít					

(2) Bức điện 1 024 bít vừa khít hai khối 512 bít. Vì sao vẫn phải sinh thêm một khối nữa?

(3) Vì sao số từ 32 bít sau khi đệm luôn chia hết cho 16?

(4) Nếu bức điện 3 000 bít đó được băm bằng SHA (đệm giống MD5, theo slide 10) thì tổng số lần biến đổi là bao nhiêu? Giải thích chênh lệch so với MD5.

Bài 5. MD5 thu nhỏ: một bước biến đổi

Giữ nguyên sơ đồ một bước biến đổi của MD5 nhưng thanh ghi chỉ 8 bít thay vì 32 bít:

$a \leftarrow b \boxplus ((a \boxplus f(b,c,d) \boxplus M_j \boxplus t_i) \lll s)$

trong đó $\boxplus$ là phép **cộng theo modulo 2^8**, $\lll s$ là quay trái s bít, và $f(b,c,d) = (b \wedge c) \vee (\neg b \wedge d)$.

Đầu vào của một bước biến đổi gồm a = `0x3D`, b = `0x6A`, c = `0xC5`, d = `0x91`, M_j = `0x27`, t_i = `0x4E` và s = 3.

(1) Tính f(b, c, d). Trình bày ở dạng nhị phân.

(2) Tính tổng $a \boxplus f \boxplus M_j \boxplus t_i$ theo modulo 2^8.

(3) Quay trái 3 bít rồi cộng b để được giá trị mới của thanh ghi a.

(4) Nếu quay **phải** 3 bít thay vì quay trái (vẫn cộng b ở cuối) thì giá trị mới của a là bao nhiêu? Nếu quay trái đúng nhưng quên bước cộng b ở cuối thì giá trị mới của a là bao nhiêu?

Bài 6. Hàm băm SHA

(1) So sánh MD5 và SHA theo bảng: độ dài cốt, số thanh ghi, số vòng, số lần biến đổi mỗi vòng, tổng số lần biến đổi mỗi khối.

Tiêu chí	MD5	SHA
Độ dài cốt		
Số thanh ghi		
Số vòng		
Số lần biến đổi mỗi vòng		
Tổng mỗi khối		

(2) SHA thu nhỏ dùng năm thanh ghi 8 bít; trong sơ đồ một vòng lặp, thanh ghi c nhận giá trị của b sau phép **quay trái**. Bản 32 bít quay trái 30 bít; bản thu nhỏ 8 bít này quy ước quay trái 6 bít. Trước một bước biến đổi, thanh ghi b mang giá trị `0xB3`. Sau bước đó thanh ghi c mang giá trị nào?

(3) Làm lại ý (2) với b = `0x5A`.

(4) Nếu một bạn quay **phải** 6 bít thay vì quay trái ở ý (2) thì ra giá trị nào? Vì sao hai kết quả khác nhau dù cùng quay 6 bít?

Bài 7. Chữ ký điện tử khác chữ ký thông thường ở những chỗ nào?

Bài 8. Sơ đồ chữ ký điện tử là bộ 5 tham số nào? Nêu ý nghĩa từng tham số.

Bài 9. A muốn gửi B một bức điện vừa được ký vừa được mã hoá. A làm theo thứ tự nào?

Bài 10. Hệ chữ ký điện tử RSA

Quy ước của bài giảng: K = {(n, p, q, a, b)} với n = p·q và $ab \equiv 1 \pmod{\varphi(n)}$; **n và b công khai**, còn **p, q, a giữ bí mật**. $\text{sig}_K(x) = x^a \bmod n$ và $\text{ver}_K(x, y) = \text{TRUE} \iff x \equiv y^b \bmod n$.

Cho p = 13, q = 19, khoá công khai b = 5.

(1) Tính n và $\varphi(n)$, rồi tìm khoá bí mật a.

(2) Ký bức điện x = 40.

(3) Xác minh chữ ký vừa tạo.

(4) Một người gửi cặp (x = 55, y = 53). Xác minh và cho biết cặp này có được chấp nhận không, vì sao.

(5) Trong hệ này, khoá nào dùng để ký và khoá nào dùng để xác minh? So sánh với chiều của phép mã hoá RSA ở chương 3.

Bài 11. Chuẩn chữ ký điện tử DSS

Thuật toán: chọn q nguyên tố; chọn p nguyên tố sao cho q chia hết (p − 1); chọn g ∈ Z_p* và tính $\alpha = g^{(p-1)/q} \bmod p$ (nếu $\alpha = 1$ thì chọn lại g); chọn a với $1 \le a \le q - 1$ và tính $\beta = \alpha^a \bmod p$. Khoá công khai là (p, q, α, β), khoá bí mật là a.

Ký bức điện x với số ngẫu nhiên k: $\gamma = (\alpha^k \bmod p) \bmod q$ và $\delta = (x + a\cdot\gamma)\cdot k^{-1} \bmod q$. Xác minh: $e_1 = x\cdot\delta^{-1} \bmod q$, $e_2 = \gamma\cdot\delta^{-1} \bmod q$, chữ ký đúng khi $(\alpha^{e_1}\cdot\beta^{e_2} \bmod p) \bmod q = \gamma$.

Cho q = 59, p = 1181 (kiểm: p − 1 = 20 × q), g = 2 và khoá bí mật a = 23.

(1) Tính α và β. Kiểm $\alpha \neq 1$.

(2) Ký bức điện x = 777 với số ngẫu nhiên k = 17. Tính lần lượt $k^{-1} \bmod q$, γ và δ.

(3) Xác minh cặp chữ ký vừa tạo: tính δ^{-1}, e_1, e_2 rồi so với γ.

(4) Giả sử trên đường truyền δ bị sửa thành 31. Xác minh lại và cho biết kết quả.

(5) Vì sao mỗi lần ký phải chọn một số k mới? Điều gì xảy ra nếu dùng lại cùng một k cho hai bức điện khác nhau?

Đáp án gợi ý

Chương 1: Tổng quan về an toàn và bảo mật thông tin

Bài 1.

TT	Mối đe doạ	Vô tình / cố ý	Thụ động / chủ động
1	Phá hoại	Vô tình	Chủ động
2	Can thiệp	Cố ý	Thụ động
3	Chưa phải đe doạ nào; điểm yếu do sơ suất	Vô tình	Thụ động (chưa tác động trực tiếp)
4	Sửa đổi	Cố ý	Chủ động
5	Can thiệp	Cố ý	Thụ động
6	Phá hoại	Cố ý	Chủ động

Bài 2. (1)

Mã	Tổn thất kỳ vọng	Thứ tự ưu tiên
R1	60 triệu	5
R2	120 triệu	3
R3	300 triệu	1
R4	100 triệu	4
R5	150 triệu	2

Tổng tổn thất kỳ vọng: **730 triệu đồng một năm**.

(2)

Giải pháp	Giảm được	Lợi ích ròng	Lợi ích / chi phí
G1	290	210	3,63
G2	108	48	1,80
G3	105	-15	0,88
G4	54	-46	0,54

(3) Chọn **G1 và G2**; tổn thất kỳ vọng còn lại **332 triệu**; G3, G4: lợi ích ròng âm. (4) Đạt, vì $332 \leq 350$; quản lý rủi ro nhằm đưa rủi ro xuống mức chấp nhận được, không phải về 0.

Bài 3. (1)

TT	Thuộc tính bị vi phạm	Công cụ bảo vệ theo bài giảng
1	Bí mật	Mã hoá
2	Toàn vẹn	Hàm băm, mã xác thực MAC
3	Sẵn sàng	Dự phòng, sao lưu, chống DDoS
4	Xác thực	Chữ ký số, chứng chỉ số
5	Sẵn sàng	Dự phòng, sao lưu

(2) Có; ví dụ mã độc tống tiền vừa mã hoá dữ liệu (vi phạm tính sẵn sàng), vừa sao chép dữ liệu ra ngoài để doạ công bố (vi phạm tính bí mật).

Bài 4. An toàn mức vật lý; an toàn mức tác nghiệp; an toàn mức quản lý và chính sách.

Bài 5. (1) 1: kẻ giả danh; 2: kẻ lạm quyền; 3: người dùng giấu mặt; 4: chưa xếp được vì chưa truy cập được vào hệ thống. (2) Tìm mục tiêu và thu thập thông tin (dò hệ thống đích) → truy cập ban đầu (vào bằng tài khoản quyền thấp) → leo thang quyền (nâng lên quyền quản trị) → xoá dấu vết (tắt, xoá nhật ký). (3) Kiểm tra các bản ghi, phân tích kiểm tra bản ghi: gần như vô hiệu vì nhật ký đã bị tắt; phát hiện thống kê bất thường, phát hiện dựa trên qui tắc (nếu có quy tắc coi việc tắt nhật ký là dấu hiệu xâm nhập): còn cơ hội.

Bài 6. Virus: đoạn mã lệnh tự sinh lặp, đính kèm với code khác; bộ tải: phần code tạo bản sao và thực hiện nhiệm vụ ngầm.

Bài 7. (1) Tự sinh lặp: virus, sâu (cột người dùng tự rước vào hoặc kẻ tấn công cài; ô người phát triển cài sẵn để trống). Không tự sinh lặp: cửa sau, bom logic (người phát triển cài sẵn); ngựa thành Tơ-roa, zombie (người dùng hoặc kẻ tấn công đưa vào). (2a) 18.000 yêu cầu/giây, **chưa quá tải**. (2b) 108.000 yêu cầu/giây, gấp **4,32 lần**. (2c) Chặn được (a); không chặn được (b) vì mỗi zombie chỉ gửi 1 yêu cầu/giây, dưới ngưỡng 2. (2d) Gấp 4,32 lần; không khả thi vì kẻ tấn công chỉ cần huy động thêm zombie. (3) Trước: vá lỗ hổng, đổi mật khẩu mặc định, thuê dịch vụ chống DDoS; trong: phát hiện lưu lượng bất thường, giới hạn tần suất, lọc theo thời gian thực; sau: lần vết nguồn tấn công, phân tích nguyên nhân.

Bài 8. (1) 76 byte; **80 byte**. (2) 80 byte và **84 byte**; **không đạt mục đích**. (3) DEP/NX bit: vùng nhớ không được thực thi; ASLR: ngẫu nhiên hoá vị trí bộ nhớ; cả hai áp dụng được cho chương trình đã biên dịch sẵn, stack canary bắt buộc biên dịch lại. (4) Ngôn ngữ C không tự kiểm tra biên; kiểm tra độ dài đầu vào trước khi ghi.

Bài 9. (1) 1: bộ lọc gói; 2: cổng mức ứng dụng; 3: AH ở chế độ vận chuyển; 4: ESP ở chế độ ống; 5: PGP (S/MIME cũng đúng). (2) Tầng mạng (IP/TCP) · Cao nhất · Không xét nội dung bên trong kết nối. (3) Cắt theo **cột**: danh sách kiểm soát truy cập (ACL); theo hàng: thẻ về khả năng (capability list), một chủ thể truy cập được những đối tượng nào. (4) Không bảo vệ được tấn công đi vòng qua nó (phát wifi từ điện thoại 4G); không chống được đe doạ từ bên trong (nhân viên sao chép dữ liệu ra USB); không chặn được việc truyền tệp nhiễm virus (tệp đính kèm thư điện tử đi qua cổng 443).

Bài 10. Xác thực nhau, thoả thuận thuật toán mã hoá và MAC, thoả thuận khoá mã.

Bài 11. Dữ liệu mã bằng khoá phiên (mã đối xứng, AES); khoá phiên mã bằng mã bất đối xứng (RSA).

Chương 2: Mã hoá khoá đối xứng

Bài 1. C = E(K, P), P = D(K, C); KE = KD.

Bài 2. (1) 1: chỉ dùng bản mã; 2: biết bản rõ; 3: chọn bản rõ; 4: chọn bản tin; từ yếu đến mạnh: 1 → 2 → 3 → 4. (2a) 2^{32} = 4.294.967.296 khoá, khoảng 71,58 phút. (2b) Khoảng 2.285 năm. (2c) Gấp đôi. (2d) 32 bít: trung bình khoảng 35,79 phút, dưới 1 giờ nên không đủ; 34 bít: trung bình khoảng 2,39 giờ, đủ. (3) An toàn không điều kiện: bản mã không chứa đủ thông tin để xác định bản rõ dù tài nguyên tính toán vô hạn; chỉ One-Time Pad đạt được. An toàn tính toán: chi phí phá mã vượt giá trị thông tin, hoặc thời gian phá mã dài hơn tuổi thọ hữu ích của thông tin; mọi hệ mã đang dùng thuộc loại này.

Bài 3. (1) `YPEHZCV`. (2) `THISISATEST`. (3) k = 9. (4) `CODE` → `VHQF`; `TYHUHVHS` → `PROTOCOL`. (5) Caesar 25 khoá; bảng chữ đơn 26! ≈ 4×10^{26} khoá; bị phá bằng thống kê tần suất chữ cái.

Bài 4. (1)

	1	2	3	4	5
1	K	E	Y	W	O
2	R	D	A	B	C
3	F	G	H	I	L
4	M	N	P	Q	S
5	T	U	V	X	Z

(2) `CR YP TO` → `RDAVZK`. (3) `SU CX CE SX SX` → `NZBZDOQZQZ`; dài hơn vì chèn X vào cặp CC, cặp SS và thêm X cho chữ S lẻ ở cuối. (4) `ME SX SA GE` → `NKQZPCND`; giải mã lại ra `MESXSAGE`, không giống hệt bản rõ ban đầu vì còn chữ X đã chèn.

Bài 5. (1) `SRDYVKKXGYR`. (2) `MATMAHOCCOBAN`. (3) `NOEIEWRSCRTTKUY`. (4) `CRYPTOGRAPHY`. (5) Một chữ rõ ứng với nhiều chữ mã khác nhau tuỳ vị trí.

Bài 6. (1) `SECURITYFIRSTXXX` → `CTRXSRFTUYSXEIIX`. (2) `MAHOANVITHEOCOT`. (3) Bản mã có đúng các chữ và số lần như bản rõ đã đệm (bản rõ gốc cộng 3 chữ X); mã hoán vị chỉ đổi chỗ chứ không đổi chữ, mã thay thế thì đổi chữ; vì vậy bản mã có tần suất chữ giống tiếng Anh là dấu hiệu của mã hoán vị.

Bài 7. (1) X = `101000`, Y = `10000110`, Z = `001000010`. (2)

Bước	x_1	y_3	z_3	m	Quay	X sau bước	Y sau bước	Z sau bước	s_i
0	0	0	0	0	X, Y, Z	`110100`	`11000011`	`000100001`	0
1	1	0	1	1	X, Z	`011010`	`11000011`	`100010000`	1
2	1	0	0	0	Y, Z	`011010`	`01100001`	`010001000`	1

(3) S = `011`, C = `110` → chữ G. (4) Hai hoặc ba thanh ghi; m là giá trị đa số nên luôn có ít nhất hai bít điều khiển bằng m, do đó không bao giờ chỉ một thanh ghi quay.

Bài 8. (1) T = `5 2 7 5 2 7 5 2`; S sau khởi tạo = `1 4 5 0 7 6 2 3`. (2) k = `0 4 6` → S = `000 100 110`. (3) C = `011 000 100` → từ DAE. (4) Không phần tử nào còn đúng vị trí ban đầu; nhiệm vụ: xáo dãy S theo khoá.

Bài 9. (1) K_1 = `111110`, K_2 = `111011`, K_3 = `001111`. (2) C = `10001110` ($8E_{16}$). (3) Trở về đúng bản rõ `01010011`. (4) `01110100`, khác bản rõ; cách này thiếu bước đổi chỗ hai nửa.

Bài 10. Mã Feistel 16 vòng; khối 64 bít; khoá 56 bít; khoá con 48 bít mỗi vòng.

Bài 11. Tấn công phát lại thông điệp (replay attack).

Bài 12. Khoá K hai người cùng biết; khi lộ khoá không có cơ sở quy trách nhiệm.

Bài 13. A gửi yêu cầu cho KDC; KDC tạo KAB, mã thành E(KAB, KA), E(KAB, KB); A, B giải mã lấy KAB; kết thúc huỷ KAB.

Chương 3: Mã hoá khoá công khai

Bài 1. Sơ đồ: bản rõ → mã hoá bằng khoá công khai của người nhận → bản mã → giải mã bằng khoá riêng của người nhận → bản rõ. Khoá công khai: mã hoá, kiểm chứng chữ ký; khoá riêng: giải mã, tạo chữ ký.

Bài 2. (1) GCD = 105. (2) GCD = 29. (3) d = 21, x = -16, y = 27. (4) d = 7, x = 5, y = -14.

Bài 3. (1) $37^{-1} \bmod 120 = \mathbf{13}$. (2) Không tồn tại; bảng dừng ở dòng 1 với $r_2 = 0$, $r_1 = 13 \neq 1$, tức GCD(26, 91) = 13. (3) x = **23**. (4) GCD(a, n) = 1; nghịch đảo là duy nhất trong Zn.

Bài 4. (1) $5^{117} \bmod 19 = \mathbf{1}$. (2) $3^{200} \bmod 23 = \mathbf{9}$. (3) 96 chữ số; rút gọn theo modulo ở mỗi bước giữ mọi số trung gian nhỏ hơn n.

Bài 5. (1) Φ(61) = 60, Φ(85) = 64, Φ(125) = 100, Φ(144) = 48. (2) $4^{102} \bmod 103 = 1$, $5^{96} \bmod 13 = 1$, $2^{100} \bmod 33 = 1$. (3) p là số nguyên tố, a không là bội của p (GCD(a, p) = 1). Ví dụ sai: viết $14^6 \bmod 7 = 1$, trong khi 14 là bội của 7 và thực tế $14^6 \bmod 7 = 0$.

Bài 6. (1) x = **116** (modulo M = 385). (2) $7^{129} \bmod 55 = \mathbf{52}$. (3) Luỹ thừa theo hai modulo nhỏ p và q rẻ hơn nhiều so với theo modulo N.

Bài 7. (1) A' siêu tăng; M = 97 > 2 × 44 = 88; u = 34 < 97 và GCD(34, 97) = 1. (2) S = (5, 73, 83, 35, 41), M = 97; Ks = (34, 20). (3) C = **26**. (4) C' = 73, P = **11011**. (5) S không còn là véc tơ siêu tăng; người nhận biết u^{-1} nên đưa C về C' và giải với A' siêu tăng.

Bài 8. (1) N = 299, Φ(N) = 264; e = 17 thoả 1 < e < 264 và GCD(17, 264) = 1. (2) d = **233**; KU = {17, 299}, KR = {233, 13, 23}. (3) C = **289**. (4) M = 100. (5) Biết p, q là tính được Φ(N) rồi suy ra d.

Bài 9. Thông báo công khai; thư mục truy cập công cộng; chủ quyền khoá công khai; chứng nhận khoá công khai.

Bài 10. Tập công nghệ, dịch vụ đảm bảo an toàn liên lạc; gồm chứng chỉ khoá công khai và hệ thống phân phối khoá tin cậy.

Bài 11. Sai; chỉ dùng để thiết lập khoá chung.

Bài 12. (1) $S = 42^{233} \bmod 299 = \mathbf{191}$; kiểm chứng $191^{17} \bmod 299 = 42 = M$ nên chữ ký hợp lệ. (2) $S^e \bmod N = 42 \neq 50$: **không hợp lệ**. (3) $y_A = 224$, $y_B = 455$, $K_{AB} = \mathbf{216}$. (4) Bài toán logarit rời rạc.

Chương 4: Hàm băm và chữ ký điện tử

Bài 1. Đầu vào kích thước biến thiên; đầu ra chuỗi độ dài cố định (cốt bức điện).

Bài 2. (1) Bên ký: z = h(x), y = sig(z), phát cặp (x, y); bên nhận: tính lại z = h(x), xét ver(z, y); bên nhận tự tính lại được cốt. (2) Không đụng độ cao: cho trước x, không tìm được $x' \neq x$ cùng cốt; đụng độ cao: không tìm được *bất kỳ* cặp x, x' nào cùng cốt; một chiều: cho trước cốt z, không tìm được x với h(x) = z. (3) 1: tính một chiều; 2: tính không đụng độ cao; 3: tính đụng độ cao. (4) Chữ ký của bức điện này dùng được cho bức điện kia.

Bài 3. (1) Nhóm 23 người bất kỳ có xác suất hai người trùng ngày sinh ít nhất là $1/2$; n ứng với số giá trị băm khác nhau, k ứng với số bức điện đem băm. (2)

Độ dài cốt	n	Số phép thử
64 bít	`2^64`	`2^32`
128 bít	`2^128`	`2^64`
160 bít	`2^160`	`2^80`

(3) n = 2^{24} = 16.777.216; khoảng 2^{12} = 4096 phép thử. (4) 262.144 giây ≈ **3,03 ngày**. (5) Cốt 128 bít chỉ cần khoảng 2^{64} phép thử; trước đây con số này vượt quá khả năng tính toán, nay đã nằm trong tầm với.

Bài 4. (1)

Bức điện	Bít "0" thêm	Tổng sau đệm	Số khối	Số từ 32 bít	Số lần biến đổi
700 bít	323	1024	2	32	128
1024 bít	511	1536	3	48	192
3000 bít	71	3072	6	96	384

(2) Bước đệm bắt buộc thêm ít nhất một bít "1", nên 1024 bít thành 1025 bít, phải đệm tới 1536 bít, tức 3 khối. (3) Mỗi khối 512 bít chứa đúng 16 từ 32 bít. (4) SHA: 480 lần (80 lần mỗi khối thay vì 64).

Bài 5. (1) f = `0xD1`. (2) Tổng = `0x83`. (3) a = **`0x86`**. (4) Quay phải: `0x70` ⊞ `0x6A` = `0xDA`; quên cộng b: `0x1C`.

Bài 6. (1) MD5: cốt 128 bít, 4 thanh ghi, 4 vòng, 16 lần mỗi vòng, 64 lần mỗi khối. SHA: cốt 160 bít, 5 thanh ghi, 4 vòng, 20 lần mỗi vòng, 80 lần mỗi khối. (2) **`0xEC`**. (3) **`0x96`**. (4) `0xCE`; quay phải 6 bít trên 8 bít tương đương quay trái 2 bít.

Bài 7. Ký: chữ ký điện tử được tính từ bức điện bằng thuật toán, không gắn vật lý vào tài liệu; kiểm tra: dùng thuật toán xác minh công khai thay vì so với chữ ký mẫu; bản sao đồng nhất với bản gốc.

Bài 8. (P, A, K, S, V): bức điện, chữ ký, không gian khoá, thuật toán ký, thuật toán xác minh.

Bài 9. Ký trước y = sigA(x), rồi mã hoá z = eB(x, y).

Bài 10. (1) n = 247, φ(n) = 216, a = **173**. (2) y = **53**. (3) y^b mod n = 40 = x: **hợp lệ**. (4) y^b mod n = 40 $\neq$ 55: **không hợp lệ**. (5) Ký bằng khoá bí mật a, xác minh bằng khoá công khai b; ngược chiều với phép mã hoá RSA.

Bài 11. (1) α = 1029, β = 1055. (2) k^{-1} mod q = 7, γ = **32**, δ = **30**. (3) δ^{-1} = 2, e_1 = 20, e_2 = 5; kết quả xác minh = 32 = γ: **đúng chữ ký**. (4) δ^{-1} = 40, e_1 = 46, e_2 = 41; kết quả xác minh = 33 $\neq$ γ = 32: **chữ ký không hợp lệ**. (5) Dùng lại k thì hai chữ ký có cùng γ; từ $\delta_1 - \delta_2 = (x_1 - x_2)\cdot k^{-1}$ mod q giải được k, rồi suy ra khoá bí mật a. Vì vậy mỗi lần ký phải chọn k mới.